

SOC ANALYST LEVEL 1

Lecture 11: Incident Response Basics

How does an L1 SOC Analyst handle a security incident from detection to escalation?

Author: [Nader Anam](#) | Duration: 3
Hours

LECTURE OBJECTIVES

- ✓ Understand the meaning of Incident Response (IR).
- ✓ Differentiate between Alert, Incident, and Response.
- ✓ Understand the phases of Incident Response.
- ✓ Know the role of an L1 Analyst in each phase.
- ✓ Know what an L1 Analyst **MUST NOT** do during an incident.
- ✓ Gather evidence methodically.
- ✓ Document an initial Incident Timeline.
- ✓ Prioritize actions during an incident.
- ✓ Know exactly when to escalate.
- ✓ Write initial recommendations without overstepping boundaries.
- ✓ Analyze a potential Ransomware scenario.
- ✓ Analyze a potential Account Compromise scenario.
- ✓ Write an Initial Incident Handling Summary.

WHY IS THIS LECTURE IMPORTANT?

So far, you have learned how to:

-  Analyze alerts and read Windows/Linux logs.
-  Analyze Phishing emails.
-  Use a SIEM and write basic KQL queries.
-  Map events to the MITRE ATT&CK framework.

But the real question is: What happens when an alert turns into a confirmed incident?

This is where Incident Response begins. An L1 Analyst must know their role precisely. Acting randomly can destroy evidence or increase the damage.

WHAT IS INCIDENT RESPONSE?

Incident Response (IR) refers to the organized approach to addressing and managing a security breach or cyberattack.

The Goals of IR:

Minimize damage

Understand what happened

Protect systems and data

Contain the threat

Support eradication

Recover systems safely

Simply put: Incident Response is a structured methodology to handle a crisis instead of reacting chaotically.

ALERT VS. INCIDENT VS. RESPONSE

Alert

A notification that requires investigation.

Example: Multiple Failed Logins.

Incident

A confirmed or highly probable security breach.

Example: Failed Logins followed by Successful Login, then encoded PowerShell and an external connection.

Response

The actions taken to handle the incident.

Example: Escalation, isolating a host, resetting a password, gathering evidence, removing a mailbox rule.

WHY ISN'T DISCOVERY ENOUGH?

Discovering the incident is only half the job.

After discovery, we must determine:

- ? What is the scale of the impact?
- ? Which systems are affected?
- ? Is the attack ongoing?
- ? Has any data been exfiltrated?
- ? Are accounts compromised?
- ? What is the evidence?
- ? What actions are we authorized to take?
- ? Who needs to be notified?
- ? How do we document what happened?

PHASES OF INCIDENT RESPONSE

The standard IR lifecycle framework (based on NIST/SANS):

1.
Preparation

2.
Identification

3.
Containment

4.
Eradication

5.
Recovery

6. Lessons
Learned

Important Note: An L1 SOC Analyst does not execute everything alone. Their role varies depending on the phase and organizational policy.

PHASE 1: PREPARATION

Preparation means being ready before an incident occurs.

Examples of preparation:

-  Having clear security policies.
-  Defining who has the authority to isolate hosts.
-  Setting up SIEM and EDR tools.
-  Preparing report templates.
-  Knowing escalation matrices.
-  Training the team.
-  Defining L1, L2, and IR Team roles.
-  Testing communication procedures.

L1 ROLE IN PREPARATION

The L1 Analyst's role during the Preparation phase:

- ✓ Understand escalation procedures.
- ✓ Familiarize themselves with report templates.
- ✓ Know all log sources and how to query them.
- ✓ Know who to contact for different types of incidents.
- ✓ Understand the limits of their authority.
- ✓ Adhere to standard Playbooks.

L1 is not responsible for building the IR plan, but they **MUST** know how to execute their part of it.

PHASE 2: IDENTIFICATION

Identification means determining whether the observed activity is an actual incident.

Key questions to ask:

- Q Is the activity genuinely malicious?
- Q Is a user or system actively affected?
- Q Is there enough evidence?
- Q Is there a measurable business impact?
- Q Is the attack ongoing?
- Q Are there correlated indicators?
- Q Does this case warrant escalation?
- Q What type of incident is this?

This phase is very similar to Alert Triage, but heavily focused on confirming the breach.

L1 ROLE IN IDENTIFICATION

The L1 Analyst's role:

-  Review the alert and gather initial evidence.
-  Identify the affected User and Host.
-  Establish the timeframe and build an initial Timeline.
-  Determine Severity and Confidence.
-  Write the Initial Analysis.
-  Escalate if the case exceeds their authority.

Example: If an L1 sees encoded PowerShell with an external connection after a user opened an attachment, they DO NOT close the case. They document and escalate.

PHASE 3: CONTAINMENT

Containment means stopping the spread of the damage.

Examples of containment actions:

- Isolating an infected machine from the network.
- Temporarily disabling a compromised account.
- Blocking a malicious IP or Domain on the firewall.
- Removing a malicious mailbox forwarding rule.
- Stopping a malware process from spreading.

Warning: Containment can impact business operations. An L1 Analyst NEVER executes major containment randomly without authorization.

L1 ROLE IN CONTAINMENT

The L1 Analyst's role usually involves:

-  Recommending containment actions.
-  Escalating to the authorized authority (L2 / IR Team).
-  Documenting the evidence that justifies the containment.
-  Following the organizational Playbook strictly.

Example Recommendation:

"Recommend isolating HR-LAPTOP-07 due to suspicious PowerShell execution and repeated outbound connections, pending Tier 2 approval."

WHAT L1 MUST NOT DO IN CONTAINMENT

An L1 Analyst MUST NOT:

- ✗ Isolate a critical production server without permission.
- ✗ Shut down a business service without authorization.
- ✗ Delete suspicious files (this destroys evidence).
- ✗ Reboot a machine before gathering volatile evidence.
- ✗ Change wide-scale configurations.
- ✗ Block public domains (like google.com) blindly.
- ✗ Confront the user aggressively or accusingly.
- ✗ Make legal or administrative decisions.

Rule: L1 documents, escalates, and suggests. They do not overstep policy.

PHASE 4: ERADICATION

Eradication means completely removing the root cause of the threat.

Examples:

-  Removing Malware from the host.
-  Deleting persistence mechanisms (Scheduled Tasks, Cron Jobs).
-  Patching the vulnerability that was exploited.
-  Removing Web Shells from servers.
-  Disabling backdoor accounts created by the attacker.
-  Deleting malicious Mailbox Forwarding Rules.

This phase is typically NOT the direct responsibility of an L1 Analyst.

L1 ROLE IN ERADICATION

The L1 Analyst's role:

- 🔍 Identify and map the exact indicators.
- 📋 Clarify to Tier 2 exactly what needs to be removed.
- 🔍 Search the SIEM to ensure the IOC doesn't exist elsewhere.
- 📝 Document any eradication actions taken by the broader team.

Do NOT delete evidence yourself unless authorized by a specific SOP.

Example: If you find a malicious Scheduled Task, do not delete it immediately. Document its name, execution time, path, and related process, then escalate.

PHASE 5: RECOVERY

Recovery means restoring systems back to normal, secure business operations.

Examples:

-  Restoring encrypted files from clean backups.
-  Reconnecting a cleaned machine back to the corporate network.
-  Re-enabling an account after a forced Password Reset.
-  Confirming the malicious indicators no longer exist.
-  Monitoring the system tightly post-recovery.

Recovery is not just "turning it back on". It's turning it back on after verifying the threat is gone.

L1 ROLE IN RECOVERY

The L1 Analyst's role:

-  Monitor the systems in the SIEM immediately after recovery.
-  Verify that the original alerts do not return.
-  Actively hunt for the original IOCs to ensure they are truly gone.
-  Ensure no new suspicious logins occur on the restored account.
-  Document the monitoring status in the ticket.

Example: After an IT admin resets a compromised password, the L1 monitors the SIEM to ensure no logins from the attacker's IP occur again.

PHASE 6: LESSONS LEARNED

Lessons Learned (or Post-Incident Activity) is a review conducted after the incident is closed.

The Goal is to answer:

- ❓ How did the attack start?
- ❓ Why wasn't it detected earlier?
- ❓ What parts of our IR plan worked well?
- ❓ What failed or caused delays?
- ❓ Do we need to write a new SIEM rule?
- ❓ Do we need better user security awareness training?
- ❓ Do we need stricter MFA policies?

L1 ROLE IN LESSONS LEARNED

The L1 Analyst's role:

-  Provide feedback from their initial analysis perspective.
-  Highlight where logs were missing or insufficient during the investigation.
-  Mention any difficulties faced during triage.
-  Suggest improvements for alert tuning to reduce noise.
-  Share the Timeline they built.
-  Learn from the decisions made by Tier 2 and the IR Team.

This phase is vital for the continuous growth of both the analyst and the SOC.

SUMMARY: SOC L1 ROLE DURING AN INCIDENT

A SOC L1 Analyst is primarily responsible for:

-  Receiving the alert.
-  Gathering initial evidence.
-  Identifying the affected User, Host, and Time.
-  Correlating events logically.
-  Building an initial Timeline.
-  Assessing Severity and Confidence.
-  Documenting the analysis professionally.
-  Escalating immediately when necessary.
-  **NOT destroying or altering evidence.**

WHAT AN L1 ANALYST MUST NOT DO

Avoid these actions at all costs:

- ✗ Do not delete suspicious files without permission.
- ✗ Do not reboot a machine without authorized reason.
- ✗ Do not isolate production servers without approval.
- ✗ Do not interrogate or accuse users.
- ✗ Do not change account privileges randomly.
- ✗ Do not close a severe incident just because you lack understanding.
- ✗ Do not execute actions outside the approved Playbook.
- ✗ Do not use unauthorized third-party analysis tools.
- ✗ Do not share incident details with unauthorized staff.

EVIDENCE YOU MUST COLLECT

During a security incident, gather these crucial data points:

General

- ⌚ Alert Name
- Date/Time
- Affected User
- Affected Host

Network/Web

- ⌚ Source IP
- Destination IP
- Domain/URL
- Network Connections

Endpoint/Malware

- 📄 File Name & Hash
- Process Name
- Parent Process
- Command Line

Email/Identity

- ⌚ Email Subject
- Attachment Name
- Authentication Events
- User Actions Taken

THE IMPORTANCE OF THE TIMELINE

A **Timeline** is the chronological ordering of events. Without it, the incident looks chaotic and confusing.

[08:00 AM] - Phishing email delivered.

[08:12 AM] - User opened attachment.

[08:13 AM] - Excel launched PowerShell.

[08:14 AM] - DNS query observed.

[08:15 AM] - Outbound connection started.

[08:30 AM] - Successful login from unknown country.

[08:35 AM] - Mailbox forwarding rule created.

The Timeline clearly illustrates how the attack evolved step-by-step.

INCIDENT TIMELINE TEMPLATE

Time	Event	Source	Evidence	Notes
09:10	Email delivered	Email Gateway	Subject / Sender	Suspicious
09:15	User clicked link	Proxy	URL	Credential phishing
09:20	Login from new country	Identity Logs	Source IP	Highly Suspicious
09:25	Forwarding rule created	Mailbox Logs	Rule name	Possible compromise

DETERMINING SEVERITY DURING IR

Severity during an incident depends on multiple factors:

- ! What is the type of incident?
- ! How many devices are affected?
- ! Is it a standard or Admin account?
- ! Is the affected system business-critical?
- ! Has data been exfiltrated?
- ! Is it Ransomware?
- ! Is the attack ongoing?
- ! Has persistence been established?
- ! Is there a confirmed business impact?
- ! Are production systems compromised?

SEVERITY EXAMPLES

Scenario	Severity
Phishing delivered without user interaction	Low / Medium
User clicked link only (no credentials)	Medium
Malware blocked before execution	Medium
User entered credentials	High
Malware executed with C2 connection	High
Account compromise with forwarding rule	High
Ransomware on a single host	High / Critical
Ransomware spreading / Data Exfiltration	Critical

DETERMINING CONFIDENCE DURING IR

Confidence refers to the strength and reliability of the evidence.

Low

Confidence: Weak indicator.

- An external connection without context.

Medium

Confidence: Corroborated indicators.

- Phishing delivery + Link click.

High

Confidence: Credentials entered + Login from unknown country + Forwarding rule.

Confirmed

÷ Indisputable evidence: Confirmed malware execution, proven data leak, or encrypted files.

| WHEN SHOULD AN L1 ESCALATE IMMEDIATELY?

Escalate immediately to Tier 2 / IR if you see:

- 🔥 Ransomware indicators (encrypted files, ransom notes).
- 🔥 Confirmed Malware execution.
- 🔥 Successful login following a brute force attempt.
- 🔥 A Privileged/Admin account is involved.
- 🔥 A Domain Controller is affected.
- 🔥 Security Audit logs have been cleared.
- 🔥 Data exfiltration is suspected (large uploads).
- 🔥 Attacker persistence has been created.
- 🔥 C2-like beaconing traffic.
- 🔥 Multiple hosts are actively affected.
- 🔥 Phishing where the user submitted credentials.
- 🔥 Mailbox forwarding rule created after phishing.

WHAT MAKES A GOOD ESCALATION?

A bad escalation looks like: "There is a problem, please check."

A professional escalation is:

- ✓ Clear and concise.
- ✓ Contains all relevant Evidence (IOCs).
- ✓ Includes a chronologically accurate Timeline.
- ✓ States the Severity and Impact.
- ✓ Clearly states the reason for escalation.
- ✓ Lists what has been checked so far.
- ✓ Lists what has NOT been checked yet.
- ✓ Includes initial containment recommendations.

STANDARD ESCALATION TEMPLATE

Incident
Severity
Confidence
Affected
Alert/Host:
Summary
Key
Timeline:
Evidence:
Potential
Actions
Impact:
Recommended Next
Reason for
Escalation
Analyst Name &
Date/Time:

EXAMPLE OF A GOOD ESCALATION

Incident Possible Account Compromise

Severity High

Affected finance.manager

User:

Summary

: The account experienced 18 failed login attempts followed by a successful RDP login from an external IP. After login, special privileges were assigned and encoded PowerShell was executed.

Reason for

Escalation: Possible account compromise with suspicious post-login activity on a sensitive account.

Recommended Next

Steps: Review MFA logs, enforce password reset, investigate the endpoint timeline for malware, and check for lateral movement.

DOCUMENTATION BEFORE ACTION

Before taking ANY significant action, you must document:

- What is the alert?

- What is the evidence?

- Who is affected?

- What is the exact time?

- What is the activity?

- What is the severity?

- Who approved the action?

- What is the exact action?

- What was the result?

Proper documentation protects the integrity of the investigation and protects the analyst.

PRESERVING EVIDENCE

Preserving evidence is critical because the incident may require:

Deeper investigation | Management review | Official reporting | Forensics | Legal action.

Evidence to explicitly save:

-  Raw SIEM Logs.
-  Full Alert details.
-  Hashes.
-  Screenshots (if necessary).
-  Email headers.
-  The built Timeline.
-  Written user confirmation.
-  Record of all actions taken.

CHAIN OF CUSTODY (SIMPLIFIED)

Chain of Custody means tracking who handled the evidence, when, and how.

For an L1 Analyst, the simplified rules are:

-  **Do not alter the original evidence.**
-  Do not delete files on the endpoint.
-  Do not change the state of the machine without documenting it.
-  Record exactly who gathered the evidence and when.
-  Save the source of the data (e.g., SIEM query used).

An L1 is not expected to be a Forensics expert, but they **MUST NOT** taint the crime scene.

FATAL ERRORS DURING INCIDENT RESPONSE

Avoid these critical mistakes:

- ✗ Deleting a malicious file immediately.
- ✗ Rebooting an infected device before forensics.
- ✗ Closing an alert without documentation.
- ✗ Isolating a production server without permission.
- ✗ Notifying unauthorized individuals.
- ✗ Changing a password without logging it.
- ✗ Failing to record the time of actions taken.
- ✗ Ignoring correlated secondary alerts.
- ✗ Treating a major incident like a standard alert.
- ✗ Delaying escalation despite clear danger.

INCIDENT RESPONSE PLAYBOOKS

A **Playbook** is a written Standard Operating Procedure (SOP) that outlines exactly what to do during a specific type of incident.

Examples of Common Playbooks:

Phishing

Malware Infection

Ransomware

Account Compromise

Data Exfiltration

Lost Device

Playbooks eliminate guesswork and make responses faster and more consistent.

WHY DOES L1 NEED A PLAYBOOK?

During an incident, there is no time for improvisation.

A Playbook helps an L1 Analyst:

-  Know the exact required steps.
-  Know exactly what evidence must be gathered.
-  Know the specific threshold for escalation.
-  Know who needs to be notified.
-  Know what actions are permitted vs. prohibited.
-  Standardize the quality of incident handling.

| PHISHING PLAYBOOK (SIMPLIFIED)

When responding to Phishing:

- ✓ Inspect Sender and Reply-To headers.
- ✓ Analyze the URL and Attachment.
- ✓ Determine the exact User Action.
- ✓ Check if the user entered their password.
- ✓ Look for Logins following the interaction.
- ✓ Check for Mailbox Forwarding Rules.
- ✓ Search for the same email across other users.
- *Recommend:* Password Reset if data was entered.
- ↑ *Escalate:* If Endpoint Execution or Account Compromise is confirmed.

MALWARE PLAYBOOK (SIMPLIFIED)

When responding to Malware:

- ✓ Identify the affected Host and User.
- ✓ Gather File Name, Path, and Hash.
- ✓ Confirm if it was Blocked or Executed.
- ✓ Analyze the Process Tree.
- ✓ Check for Network Connections (C2).
- ✓ Search for the Hash on other devices.
- ✓ Look for Persistence mechanisms.
- *Recommend:* Host Isolation if execution is confirmed.
- ↑ *Escalate:* If Execution, C2 traffic, or lateral spread is seen.

| ACCOUNT COMPROMISE PLAYBOOK (SIMPLIFIED)

When responding to Account Compromise:

- ✓ Identify the compromised Account.
- ✓ Review Failed/Successful Logins.
- ✓ Analyze Source IP and Geo-location.
- ✓ Check MFA status and prompts.
- ✓ Review devices associated with the account.
- ✓ Check for Mailbox Forwarding Rules.
- ✓ Review post-login Cloud Activity.
- *Recommend:* Password Reset and Revoke Sessions.
- ↑ *Escalate:* If it's a privileged account or malicious activity occurred post-login.

RANSOMWARE PLAYBOOK (SIMPLIFIED)

When responding to potential Ransomware:

-  Do not treat it as a standard alert. Time is critical.
-  Quickly identify affected devices.
-  Gather process names and file extensions.
-  Document the exact time the first symptoms appeared.
-  Review EDR alerts for mass file modifications.
-  **DO NOT DELETE EVIDENCE OR REBOOT.**
-  **ESCALATE IMMEDIATELY.**
-  Strictly follow the organization's isolation and communication policy.

DATA EXFILTRATION PLAYBOOK (SIMPLIFIED)

When responding to potential Data Exfiltration:

- ✓ Identify the User and Host.
- ✓ Identify the external destination IP/URL.
- ✓ Determine the volume (size) of the data.
- ✓ Determine the time of the transfer.
- ✓ Identify the data type if possible.
- ✓ Review File Access Logs.
- ✓ Review Authentication Logs (was it preceded by a compromise?).
- ↑ *Escalate:* Immediately if the data is sensitive or volume is unusually large.

SCENARIO 1: PHISHING TO CREDENTIAL THEFT

User: mona

Email: MFA Verification Required

Action: User clicked link and entered password.

Event: After 8 minutes, login from unknown country.

Event: Mailbox forwarding rule created.

Tasks: Is this an Incident? What type? What is the evidence? Recommended actions? Do you escalate?

| ANSWER TO SCENARIO 1

Analysis: Yes, this is a highly probable Incident.

Type: Credential Phishing / Account Compromise

Evidence: User submitted password, unusual login location, malicious forwarding rule.

Recommended Actions:

Reset password & Revoke sessions.

Review MFA.

Remove forwarding rule.

Search for suspicious sent emails.

Severity: High

Decision: Escalate to Tier 2.

SCENARIO 2: MALWARE EXECUTION

Host: HR-LAPTOP-09

Action: User opened salary_update.xlsm.

Event: excel.exe launched powershell.exe -enc.

Event: Outbound connection to 91.200.10.5:443 every 60 seconds.

EDR Action: Allowed.

Tasks: Is this an incident? What is the evidence? Map to MITRE. Recommended actions? Do you escalate?

| ANSWER TO SCENARIO 2

Analysis: This goes beyond a simple Phishing alert; it is an active Endpoint Compromise.

Evidence: xlsx file, encoded PowerShell execution, repeated external connection (EDR failed to block).

MITRE Mapping:

Initial Access: Phishing (likely)

Execution: PowerShell

C2: Repeated outbound connection

Severity: High

Decision: Escalate.

Actions: Recommend Isolation, review EDR timeline, investigate email source.

SCENARIO 3: POTENTIAL RANSOMWARE

Event: Several users report files cannot be opened.

Event: Files have a new strange extension.

Event: README_RESTORE_FILES.txt appears.

EDR: Detects unknown.exe modifying hundreds of files.

Tasks: What type of incident is this? Indicators? What is the L1 role? What should you NOT do? Escalate?

| ANSWER TO SCENARIO 3

Type: Possible Ransomware Incident

Indicators: Inaccessible files, strange extension, ransom note, massive file modifications.

L1 Role:

Document evidence & identify affected hosts.

Identify first time of symptoms.

Check for lateral spread.

Escalate Immediately.

What NOT to do: Do not delete files, do not reboot systems randomly, do not act outside the playbook.

Severity: Critical

SCENARIO 4: POTENTIAL DATA EXFILTRATION

User: finance.user | **Host:** FIN-PC-03

Event: Large upload: 5 GB

Destination: IP 185.20.40.9 at 02:30 AM

Previous Alert: Login from New Country

Tasks: Incident type? Indicators? Missing evidence? Recommended actions? Escalate?

| ANSWER TO SCENARIO 4

Type: Possible Data Exfiltration

Indicators: Massive upload, unusual time, external destination, financial account, preceded by suspicious login.

Missing Evidence:

What file types were accessed?

Is the destination IP a known service?

Did the user authorize this?

Severity: High / Critical

Decision: Escalate immediately. Document all network flow details.

FULL TRAINING SCENARIO

Incident: Possible Phishing-led Compromise with C2 and Lateral Movement

Email delivered to user Ahmed with attachment invoice.docm.

User opened attachment. winword.exe launched powershell.exe -enc.

DNS Query to invoice-update-check.example.

Outbound connection to 91.200.10.5:443 every 60 seconds.

Scheduled Task created: OfficeUpdate.

12 Failed Logins from Ahmed's host to FILE-SRV-01, followed by a Successful Login.

Large file archive created, and 3 GB uploaded to external IP.

Tasks: Identify incident type, build timeline, map MITRE, determine Severity/Confidence, define L1 role, suggest actions, write Incident Summary.

| SCENARIO ANSWER: INCIDENT TYPE

Phishing-led endpoint compromise with possible C2, persistence, lateral movement, and data exfiltration.

This is not a single simple incident. It is a complete, chained attack lifecycle.

SCENARIO ANSWER: TIMELINE

1. Email delivered to Ahmed.
2. User opened invoice.docm.
3. Word launched encoded PowerShell.
4. DNS query to suspicious domain.
5. Repeated outbound connection to external IP.
6. Scheduled Task OfficeUpdate created.
7. Failed logins to FILE-SRV-01.
8. Successful login to FILE-SRV-01.
9. Large archive created.

SCENARIO ANSWER: MITRE MAPPING

Event	MITRE Tactic
Phishing email	Initial Access
User opened attachment	User Execution
Word launched PowerShell	Execution
DNS + repeated connection	Command and Control
Scheduled Task	Persistence
Failed/Successful login to FILE-SRV-01	Lateral Movement
Archive created	Collection
3 GB upload	Exfiltration

SCENARIO ANSWER: SEVERITY & CONFIDENCE

Severity: Critical

PowerShell execution.

Repeated C2 communication.

Persistence mechanism established.

Lateral Movement to a File Server.

Massive upload suggesting Data Exfiltration.

Confidence: High

Multiple correlated evidence sources.

Clear logical timeline.

Activity spans Endpoint, Network, Auth, and Data movement.

| SCENARIO ANSWER: L1 ROLE & ACTIONS

L1 Responsibilities for this case:

Document all evidence and finalize the Timeline.

Identify all affected Hosts and Accounts.

Extract all IOCs (Domain, IP, Task name, File names).

Hunt across the SIEM for these same IOCs elsewhere.

Do NOT delete files or tasks manually.

Escalate immediately to Tier 2 / Incident Response.

Acknowledge and follow any containment instructions from the IR team.

INCIDENT HANDLING SUMMARY

"The incident appears to have started with a phishing email containing a malicious document attachment. After the user opened the attachment, Microsoft Word launched encoded PowerShell, followed by DNS activity to a suspicious domain and repeated outbound connections to 91.200.10.5:443, indicating possible C2 communication. A Scheduled Task named OfficeUpdate was created, suggesting persistence. The host then attempted and successfully logged in to FILE-SRV-01, indicating possible lateral movement. A large archive was created and 3 GB of data was uploaded to an external IP, suggesting possible data exfiltration. This incident is Critical and requires immediate escalation to Tier 2 / Incident Response."

| WHAT SHOULD L1 DO AFTER ESCALATION?

After escalating, you do not just abandon the ticket. You must:

- + Add any newly discovered evidence.
- ↩ Promptly answer questions from Tier 2.
- 🖥 Continue monitoring the indicators.
- 🔍 Keep hunting for the IOCs in the environment.
- 📝 Document any actions the IR team asks you to perform.
- 🕒 Update the Timeline if new events are found.

Do not alter the incident status or close the ticket unless authorized by policy.

COMMON MISTAKES IN INCIDENT RESPONSE

- ✗ Taking action before documenting the evidence.
- ✗ Deleting crucial evidence (files/tasks).
- ✗ Failing to build a logical Timeline.
- ✗ Failing to map the full blast radius (affected users/hosts).
- ✗ Hesitating to escalate a clear threat.
- ✗ Escalating blindly without providing evidence.
- ✗ Executing containment without authorization.
- ✗ Ignoring the "User Action" context.
- ✗ Not searching for lateral spread.
- ✗ Ignoring the "Lessons Learned" phase.

THE GOLDEN RULE



"In Incident Response, speed is essential. But speed without accuracy is dangerous."

Do not delay escalation, but do not escalate an empty claim.

A good escalation contains: What happened? When? Who is affected? Evidence? Timeline? Severity? Actions Taken? Next Steps?

LECTURE SUMMARY

- ✓ The true meaning of Incident Response.
- ✓ Difference between Alert, Incident, and Response.
- ✓ The 6 phases of Incident Response.
- ✓ The specific role of SOC L1 in each phase.
- ✓ Actions an L1 must strictly avoid.
- ✓ The importance of Evidence and Timelines.
- ✓ When to escalate immediately.
- ✓ The reliance on Standard Playbooks.
- ✓ Handling Phishing, Malware, Compromise, and Ransomware.
- ✓ Writing a robust Incident Handling Summary.

REVIEW QUESTIONS

- 1 What does Incident Response mean?
- 2 What is the difference between an Alert and an Incident?
- 3 What are the standard phases of Incident Response?
- 4 What is the SOC L1 role during the Identification phase?
- 5 Why shouldn't you delete a suspicious file immediately?
- 6 What does Containment mean?

- 1 What is the difference between Eradication and Recovery?
- 2 Why is building a Timeline so critical?
- 3 When should a SOC L1 escalate an issue immediately?
- 4 Why is an IR Playbook important?
- 5 What basic evidence must be gathered during an incident?
- 6 What must be documented before taking any containment action?

KNOWLEDGE ASSESSMENT QUIZ

1. Incident Response means:

A) Deleting alerts | B) **An organized approach to handling a security breach** | C) Installing OS | D) Network Design

2. The primary role of an L1 Analyst during an incident is:

A) Deleting files | B) **Gathering evidence, documenting, and escalating** | C) Shutting down everything | D) Rebooting servers

3. Containment means:

A) **Stopping the spread of the damage** | B) Writing a marketing ad | C) Deleting logs | D) Ignoring the incident

4. A potential Ransomware incident severity should usually be:

A) Low | B) **High or Critical** | C) Does not require escalation | D) Always False Positive

5. A Timeline helps to:

A) **Chronologically order events to understand the story** | B) Change passwords only | C) Delete files | D) Disable SIEM

6. An L1 Analyst **MUST NOT**:

A) Document evidence | B) Build a Timeline | C) **Delete evidence without permission** | D) Escalate severe incidents

LECTURE HOMEWORK

Analyze the following Incident:

Incident Name: Possible Account Compromise with Data Exfiltration

User: finance.manager

20 Failed Logins from an external IP.

Successful Login from the same IP, followed by Login from New Country.

Event ID 4672 (Special Privileges).

PowerShell -enc executed.

DNS Query to finance-doc-check.example.

Outbound connection to 45.77.20.10:443 every 60 seconds.

Large archive file created, and 4 GB uploaded to external IP.

Mailbox forwarding rule created.

HOMework ANSWER TEMPLATE

Incident Handling Template:

Incident Name:

Affected User:

Affected Host:

Incident Type:

Timeline:

Key Evidence:

MITRE Mapping:

Severity:

Confidence:

Potential Impact:

Actions Taken:

Recommended Actions:

Escalation Required: Yes/No

What L1 Should Not Do:

Incident Handling Summary:

HOMework BRIEF ANSWER KEY

Incident Type: Possible account compromise with suspicious execution, possible C2, mailbox compromise, and data exfiltration.

Severity: Critical | **Confidence:** High

MITRE Mapping: Credential Access (Failed logins), Valid Account (Successful login), Privileged Access (4672), Execution (PS -enc), C2 (repeated outbound), Collection (Archive), Exfiltration (4GB upload), Persistence (Forwarding rule).

Summary The user finance.manager experienced 20 failed logins from an external IP followed by a successful login from the same source and a login from a new country. A special privileges event was observed, followed by encoded PowerShell execution and DNS activity to a suspicious domain. The host then established repeated outbound connections to 45.77.20.10:443. A large archive was created and 4 GB of data was uploaded to an external IP, while a mailbox forwarding rule was also created. This indicates a likely account compromise with suspicious execution and possible data exfiltration. The incident is Critical and requires immediate escalation to Tier 2 / Incident Response.

COMING UP NEXT...



Lecture 12: Incident Report Writing

Learning how to document your findings professionally.

Why Reporting Matters | Summary vs Analysis vs Verdict | Writing Incident Titles
Formatting Evidence | Building Report Timelines | Escalation Notes | Common Mistakes

INSTRUCTOR GUIDE: SUGGESTED TIME ALLOCATION

Time	Activity Focus
15 Minutes	Review KQL and Previous Lecture concepts
20 Minutes	Explain the meaning of Incident Response
30 Minutes	Deep dive into the 6 Phases of Incident Response
25 Minutes	SOC L1 Role and strict boundaries of authority
25 Minutes	Evidence collection and Timeline building
25 Minutes	Reviewing IR Playbooks (Phishing, Malware, etc.)
30 Minutes	Short Scenarios (1 to 4)
25 Minutes	Full Scenario Walkthrough
15 Minutes	Short Quiz
10 Minutes	Summary and Homework Assignment

| INSTRUCTOR GUIDE: FOCUS POINTS

- ③ Ensure students do not think L1 executes all IR procedures. Focus heavily on Documentation and Escalation.
- ③ Repeatedly emphasize that deleting evidence is a fatal error.
- ③ Connect IR to the previous lectures (Logs, Phishing, SIEM).
- ③ Use Playbooks as a structured way of thinking rather than just reading lists.
- ③ Train students rigorously on building a chronological Timeline.
- ③ Clearly differentiate between Containment, Eradication, and Recovery.
- ③ Reinforce the strict boundaries of L1 authority.
- ③ Do not accept an escalation that lacks evidence or a timeline.
- ③ Do not accept delayed escalation in critical cases like Ransomware.

INSTRUCTOR GUIDE: EXPECTED STUDENT MISTAKES

Mistake 1: Premature Deletion

The student wants to delete a malicious file immediately.

Correction: Remind them this destroys evidence. They must follow the playbook, document, and escalate.

Mistake 2: Random Reboots

The student reboots the infected machine.

Correction: Reboots destroy volatile memory evidence and alter system state. Only do this if dictated by policy.

Mistake 3: Skipping Timelines

The student investigates without building a Timeline.

Correction: Emphasize that without a Timeline, it is impossible to understand attack progression or patient zero.

Mistake 4: Phase Confusion

Confusing Containment with Eradication.

Correction: Containment = Stopping the bleeding. Eradication = Removing the bullet. Recovery = Healing the patient.

CLOSING MESSAGE TO STUDENTS



"Incident Response is not about reckless bravery. It is about strict discipline."

Gather evidence. Build your Timeline. Understand the impact. Know your boundaries. Never destroy evidence. Never delay an escalation. Never escalate blindly. Document absolutely everything.

From now on, any incident handled without a Timeline, Evidence, Severity, Decision, and Escalation Notes is considered an incomplete response.